Laboratório de Criptografia AES-128-GCM

Material de leitura do módulo especial

1. Criptografia simétrica

AES (Advanced Encryption Standard) é uma cifra simétrica: a mesma chave que cifra a mensagem também a decifra. Ele trabalha com blocos de 128 bits e aceita chaves de 128, 192 ou 256 bits. Neste laboratório usamos a chave de 128 bits, ou seja, 16 bytes.
Cifras simétricas são rápidas e por isso aparecem em toda parte: conexões HTTPS, arquivos no disco, mensagens e backups. O desafio é o mesmo de sempre: as duas partes precisam combinar a chave secreta sem que ninguém a descubra.

2. O que o modo GCM acrescenta

O AES sozinho cifra um bloco. Para cifrar mensagens maiores, ele precisa de um modo de operação. O GCM (Galois/Counter Mode) combina o modo CTR, que cifra os dados, com um código de autenticação chamado GHASH.
O resultado não é apenas o texto cifrado: o GCM também produz uma tag de autenticação. Quem recebe a mensagem calcula a tag de novo e compara. Se um único byte do texto cifrado tiver sido alterado, a verificação falha e a decifração é recusada, em vez de devolver um texto sem sentido.

3. Nonce: o número que nunca se repete

Cada mensagem recebe um nonce aleatório de 12 bytes. O nonce não é secreto, mas precisa ser único para cada mensagem cifrada com a mesma chave. Se o mesmo nonce for reutilizado, a segurança do GCM é comprometida.
É por causa do nonce que a mesma mensagem, cifrada com a mesma chave, gera textos cifrados diferentes a cada vez. Isso é proposital: impede que duas mensagens iguais sejam reconhecidas apenas olhando o texto cifrado.

4. A frase-chave e o PBKDF2

Uma frase-chave digitada por uma pessoa não tem necessariamente os 16 bytes exatos que o AES espera, e também não tem aleatoriedade suficiente. Por isso o laboratório usa PBKDF2-HMAC-SHA256, com um salt aleatório de 16 bytes e 600.000 repetições.
O salt garante que a mesma frase-chave produza chaves diferentes em dispositivos diferentes, o que atrapalha tabelas prontas de senhas. As repetições deixam cada tentativa de adivinhar a frase-chave mais cara para um atacante.

5. O envelope

O laboratório não guarda a chave. O que ele mostra é um envelope com tudo que é necessário para decifrar, menos a chave: a versão do formato, o salt, o nonce, o texto cifrado e a tag de autenticação. Quem tiver o envelope e a frase-chave consegue decifrar; sem a chave, a mensagem é irrecuperável.

6. Boas práticas

- Use frases-chave longas e difíceis de adivinhar.
- Nunca reutilize um nonce com a mesma chave; deixe a biblioteca gerar o nonce.
- Guarde o envelope completo. Sem o salt, o nonce ou a tag, a decifração falha.
- Não publique dados sensíveis no mural: o laboratório não grava nada no banco.

- Em produção, use bibliotecas auditadas, como a cryptography do Python ou o libsodium.

7. O que você vai testar

Depois de terminar a leitura e responder ao quiz, o botão do laboratório é liberado.
Nele você pode cifrar uma mensagem, copiar o envelope, decifrar com a mesma frase-chave e tentar decifrar com uma chave errada para ver a autenticação recusar o texto.
Nada do que você escrever no laboratório é salvo ou publicado: o texto existe apenas na sessão do seu navegador.